



Weekly IT Security Brief (Official-source-first) | 2026-07-19 06:00

Formatted for readability · Auto-generated



Weekly Summary

- Priority snapshot: 5 KEV-listed vulnerabilities are actively exploited in the wild (top 8 shown in this brief).
- Urgent patch focus: CVE-2026-58644(2026-07-19), CVE-2026-25089(2026-07-19), CVE-2026-39808(2026-07-19). Prioritize internet-facing and privileged systems first.
- Threat trend #1: Microsoft at Black Hat USA 2026: Defending trust in the age of AI and supply chain attacks. Join Microsoft Security at Black Hat USA 2026 for supply chain research, hands-on security experiences, expert conversations, and our reception. The p...
- Threat trend #2: ACR Stealer: Two observed intrusion chains amid increased threat activity. From late April 2026 to mid-June 2026, Microsoft Defender Experts observed increased ACR Stealer activity across customer environments. These campaigns are successfull...
- Recommended action this week: patch KEV/high-risk exposed services within 24 hours and tighten monitoring for anomalous login, command execution, and credential access patterns.



Report A: CVE Deep Dive (CISA KEV + NVD)

CVE-2026-58644

CVE Title	CVE-2026-58644 microsoft/sharepoint_server Deserialization
CVE Description	Deserialization of untrusted data in Microsoft Office SharePoint allows an unauthorized attacker to execute code over a network.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	microsoft/sharepoint_server
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-07-19
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-58644

CVE-2026-25089

CVE Title	CVE-2026-25089 fortinet/fortisandbox Unknown Type
CVE Description	A improper neutralization of special elements used in an os command ('os command injection') vulnerability in Fortinet FortiSandbox 5.0.0 through 5.0.5, FortiSandbox 4.4.0 through 4.4.8, FortiSandbox 4.2 all versions, FortiSandbox Cloud 5.0.4 through 5.0.5, FortiSandbox PaaS 5.0.4 through 5.0.5 may allow an unauthenticated attacker to execute unauthorized commands via specifically crafted HTTP requests
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	fortinet/fortisandbox, fortinet/fortisandbox_cloud, fortinet/fortisandbox_paas
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-07-19
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-25089

CVE-2026-39808

CVE Title	CVE-2026-39808 fortinet/fortisandbox Unknown Type
CVE Description	A improper neutralization of special elements used in an os command ('os command injection') vulnerability in Fortinet FortiSandbox 4.4.0 through 4.4.8 may allow attacker to execute unauthorized code or commands via <insert attack vector here>
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	fortinet/fortisandbox
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-07-19
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-39808

CVE-2026-46817

CVE Title	CVE-2026-46817 oracle/e-business_suite Unknown Type
CVE Description	Vulnerability in the Oracle Payments product of Oracle E-Business Suite (component: File Transmission). Supported versions that are affected are 12.2.3-12.2.15. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Payments. Successful attacks of this vulnerability can result in takeover of Oracle Payments. CVSS 3.1 Base Score 9.8 (Confidentiality, Integri...
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	oracle/e-business_suite
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-07-18
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-46817

CVE-2023-4346

CVE Title	CVE-2023-4346 knx/connection_authorization Unknown Type
CVE Description	KNX devices that use KNX Connection Authorization and support Option 1 are, depending on the implementation, vulnerable to being locked and users being unable to reset them to gain access to the device. The BCU key feature on the devices can be used to create a password for the device, but this password can often not be reset without entering the current password. If the device is configured to interface with a netw...
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	knx/connection_authorization
Risk Score	7.5 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-07-29
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2023-4346



Report A2: Newly Published CVEs (NVD, last 7 days)

CVE-2026-15470

CVE Title CVE-2026-15470 | 待核實 | Unknown Type

CVE Description A vulnerability has been found in Eleveo Call Recording Software 9.7.0. Affected by this issue is some unknown functionality of the file /callrec/group.jsp. Such manipulation leads to improper authorization. The attack may be launched remotely. The exploit has been disclosed to the public and may be used. The vendor was contacted early about this disclosure but did not respond in any way.

Affected Products 待核實

Risk Score 4.3 (MEDIUM)

Source <https://nvd.nist.gov/vuln/detail/CVE-2026-15470>

CVE-2026-15471

CVE Title CVE-2026-15471 | 待核實 | Unknown Type

CVE Description A vulnerability was found in Eleveo Call Recording Software 9.7.0. This affects an unknown part of the file /callrec/pci_dss_status.jsp. Performing a manipulation results in improper authorization. Remote exploitation of the attack is possible. The exploit has been made public and could be used. The vendor was contacted early about this disclosure but did not respond in any way.

Affected Products 待核實

Risk Score 4.3 (MEDIUM)

Source <https://nvd.nist.gov/vuln/detail/CVE-2026-15471>

CVE-2026-15472

CVE Title CVE-2026-15472 | 待核實 | Unknown Type

CVE Description A vulnerability was determined in Eleveo Call Recording Software 9.7.0. This vulnerability affects unknown code of the file /callrec/composeEmailAction.do. Executing a manipulation can lead to improper authorization. The attack can be executed remotely. The exploit has been publicly disclosed and may be utilized. The vendor was contacted early about this disclosure but did not respond in any way.

Affected Products 待核實

Risk Score 4.3 (MEDIUM)

Source <https://nvd.nist.gov/vuln/detail/CVE-2026-15472>

CVE-2026-15473

CVE Title CVE-2026-15473 | 待核實 | Unknown Type

CVE Description A vulnerability was identified in Eleveo Call Recording Software 9.7.0. This issue affects some unknown processing of the file /callrec/restoreCallAction.do of the component Recorded Calls Page. The manipulation leads to improper authorization. The attack is possible to be carried out remotely. The exploit is publicly available and might be used. The vendor was contacted early about this disclosure but did not respo...

Affected Products 待核實

Risk Score 6.3 (MEDIUM)

Source <https://nvd.nist.gov/vuln/detail/CVE-2026-15473>



Report B: Threat Intelligence News (last 7 days)

Headline: Microsoft at Black Hat USA 2026: Defending trust in the age of AI and supply chain attacks

Source	Microsoft Security Blog
Published	Fri, 17 Jul 2026 16:00:00 +0000
Key Takeaway	Join Microsoft Security at Black Hat USA 2026 for supply chain research, hands-on security experiences, expert conversations, and our reception. The post Microsoft at Black Hat USA 2026: Defending trust in the age of AI and supply chain attacks appeared first on Microsoft Security Blog . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	technology/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/07/17/microsoft-at-black-hat-usa-2026-defending-trust-in-the-age-of-ai-and-supply-chain-attacks/

Headline: ACR Stealer: Two observed intrusion chains amid increased threat activity

Source	Microsoft Security Blog
Published	Thu, 16 Jul 2026 23:12:02 +0000
Key Takeaway	From late April 2026 to mid-June 2026, Microsoft Defender Experts observed increased ACR Stealer activity across customer environments. These campaigns are successfully using ClickFix lures to steal browser credentials, authentication tokens, and sensitive documents from enterprise environments. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movemen...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	technology/待核實
Technique	Credential Access
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/07/16/acr-stealer-two-observed-intrusion-chains-amid-increased-threat-activity/

Headline: CISA and Partners Publish Guidance to Help Software Manufacturers and Online Service Providers Work With Security Researchers

Source	CISA News
Published	Wed, 15 Jul 26 12:00:00 +0000
Key Takeaway	CISA and Partners Publish Guidance to Help Software Manufacturers and Online Service Providers Work With Security Researchers Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-and-partners-publish-guidance-help-software-manufacturers-and-online-service-providers-work

Headline: CISA Joins NSA, FBI, DC3 and International Partners Warning of Russian Cyber Threat Activity Targeting Communications, Energy, Government a...

Source	CISA News
Published	Tue, 14 Jul 26 12:00:00 +0000
Key Takeaway	CISA Joins NSA, FBI, DC3 and International Partners Warning of Russian Cyber Threat Activity Targeting Communications, Energy, Government and Other Critical Infrastructure Sectors Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	government/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-joins-nsa-fbi-dc3-and-international-partners-warning-russian-cyber-threat-activity-targeting

Headline: Begun, the Patch Wars have

Source	Cisco Talos Blog
Published	Thu, 16 Jul 2026 18:00:50 GMT
Key Takeaway	Begun, the Patch Wars have Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://blog.talosintelligence.com/begun-the-patch-wars-have/

Headline: The Hunter's Paradox: Is it time to embrace automated threat hunting?

Source	Cisco Talos Blog
Published	Thu, 16 Jul 2026 10:00:07 GMT
Key Takeaway	Humans can no longer keep up with the volume and velocity of security data on their own, but AI can't be fully trusted. David discusses the merits of both and muses on what the future might look like. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://blog.talosintelligence.com/the-hunters-paradox-is-it-time-to-embrace-automated-threat-hunting/

Headline: New wp2shell WordPress Core Flaw Lets Unauthenticated Attackers Run Code

Source The Hacker News

Published Sat, 18 Jul 2026 02:50:10 +0530

Key Takeaway The bug is in core, so a bare install with zero plugins is exploitable. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target unknown-target

Technique Exploit Chain

MITRE ATT&CK Unverified

Related CVEs None

Link <https://thehackernews.com/2026/07/new-wp2shell-wordpress-core-flaw-lets.html>

Headline: OpenSSL HollowByte Flaw Could Freeze Server Memory with 11-Byte TLS Requests

Source	The Hacker News
Published	Sat, 18 Jul 2026 01:50:53 +0530
Key Takeaway	Eleven bytes will make an unpatched OpenSSL server set aside up to 131 KB of memory for a message that never arrives. On the glibc systems Okta tested, that memory is gone until the process restarts. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://thehackernews.com/2026/07/openssl-hollowbyte-flaw-could-freeze.html

Headline: In Other News: Iran Tracks US Military Phones, CrashStealer macOS Malware, CVD Blueprint

Source	SecurityWeek
Published	Fri, 17 Jul 2026 14:27:54 +0000
Key Takeaway	Noteworthy stories that might have slipped under the radar: OpenClaw AI agents exploited via WhatsApp, ransomware hits naval defense firm TKMS, Lidl discloses data breach. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	defense/待核實
Technique	Malware Deployment
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/in-other-news-iran-tracks-us-military-phones-crashstealer-macos-malware-cvd-blueprint/

Headline: Podcast: Broken Governance, Agentic AI, and the MindStone Agent Exclusive

Source	SecurityWeek
Published	Fri, 17 Jul 2026 12:11:22 +0000
Key Takeaway	(Video) Artificial intelligence is transforming cybersecurity, but are governance, compliance, and security practices evolving fast enough to keep up? The post Podcast: Broken Governance, Agentic AI, and the MindStone Agent Exclusive appeared first on SecurityWeek . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/podcast-broken-governance-agentic-ai-and-the-mindstone-agent-exclusive/

Headline: Update now: 7-Zip fixes RCE flaw exploitable with malicious archives

Source BleepingComputer

Published Sat, 18 Jul 2026 15:32:02 -0400

Key Takeaway 7-Zip version 26.02 was released to fix a remote code execution vulnerability that could allow attackers to execute malicious code by convincing users to open specially crafted compressed files.
Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target ot/待核實

Technique Exploit Chain

MITRE ATT&CK Unverified

Related CVEs None

Link <https://www.bleepingcomputer.com/news/security/update-now-7-zip-fixes-rce-flaw-exploitable-with-malicious-archives/>

Headline: WordPress Core "wp2shell" RCE flaws get public exploits, patch now

Source BleepingComputer

Published Sat, 18 Jul 2026 13:22:47 -0400

Key Takeaway Public exploits have been released for the critical "wp2shell" remote code execution vulnerabilities affecting WordPress Core, making it imperative that administrators patch their sites immediately.
Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target ot/待核實

Technique Exploit Chain

MITRE ATT&CK Unverified

Related CVEs None

Link <https://www.bleepingcomputer.com/news/security/wordpress-core-wp2shell-rce-flaws-get-public-exploits-patch-now/>

Sources (official/authoritative first)

<https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

<https://nvd.nist.gov/>

<https://www.cve.org/>

<https://attack.mitre.org/>

[**https://www.microsoft.com/en-us/security/blog/**](https://www.microsoft.com/en-us/security/blog/)

[**https://www.cisa.gov/news-events/cybersecurity-advisories**](https://www.cisa.gov/news-events/cybersecurity-advisories)

[**https://www.mandiant.com/resources**](https://www.mandiant.com/resources)

[**https://blog.talosintelligence.com/**](https://blog.talosintelligence.com/)